Facultad de Ingeniería y Arquitectura · EP Ingeniería de Sistemas

DESARROLLO DE APLICACIONES MÓVILES

Actividad Autónoma N.º 10

Validación de expiración almacenamiento y cierre de sesión

Dato	Detalle
Estudiante	Juan Paredes Cárdenas
Docente	Mg. Reyna Barreto Benjamin David
Ciclo y semestre	VI · 2026-2
Unidad y sesión	Unidad 2 · Sesión 10
Fecha de ejecución	15 de octubre de 2026
Entrega límite	19 de octubre de 2026 · 23:59, America/Lima
Modalidad	Individual · Android y MySQL 8.4.11
Rama de entrega	feature/autonoma-sesion10-paredes

Los cuatro productos se verificaron mediante peticiones reales de PharmaMobil a PharmaSoft. La expiración se esperó realmente; se inspeccionó el XML cifrado del emulador; se comprobó el cierre del cliente HTTP y se registró la matriz de permisos.

Abrir rama y commits en GitHub

Se utiliza Android en Windows. No se dispone de una ejecución macOS/iOS para esta actividad y no se atribuye esa validación a otra persona.

ACTIVIDAD AUTÓNOMA N.º 10

Productos y trazabilidad

Producto	Evidencia incluida
1 Bitácora de seis escenarios	Páginas 3 a 8. Pasos, horas, HTTP, mensaje literal, captura Android y conclusión.
2 Almacenamiento seguro	Páginas 9 a 11. XML real cifrado, registro Ktor saneado y restauración tras force-stop.
3 Cierre completo	Página 12. Eliminación del token, caché HTTP, limpieza de interfaz y prueba de Atrás.
4 Matriz de permisos	Páginas 13 y 14. Seis operaciones por tres usuarios y observaciones reales de interfaz.
Análisis y repositorio	Páginas 15 y 16. Hallazgos, commits, reproducción y lista de cotejo.

Entorno ejecutado

Android Emulator Medium_Phone_API_37.0, paquete pe.edu.upeu.pharmamobil, Java 21, Spring Boot 4 y MySQL 8.4.11. Android utiliza http://10.0.2.2:8080/api/v1/. Las pruebas no usan respuestas MockEngine como evidencia HTTP del servidor.

Preparación reversible

El backend se inició temporalmente con --app.jwt.expiracion-minutos=1 y perfil mysql. El escenario 6 deshabilitó admin en MySQL con una sesión abierta. El usuario se reactivó mediante finally y la duración se devolvió a 60 minutos, verificándolo con un login posterior.

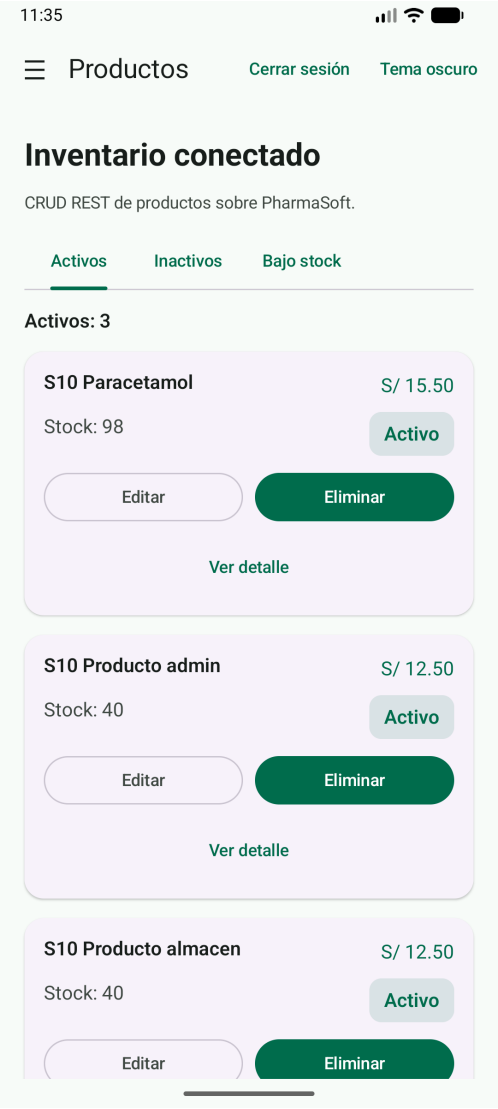
Control final	Resultado
Expiración final	3600 segundos, verificada con POST auth/login
Estado final de admin	Habilitado en MySQL
Pruebas de backend	27 aprobadas: 21 existentes y 6 del filtro JWT
Pruebas compartidas	65 host aprobadas en la compilación de esta actividad
Pruebas Android de la actividad	3 pruebas de instrumentación reales aprobadas

Los originales JSON, XML, PNG, logs de prueba y la colección importable en Postman se entregan junto al código en evidencias/sesion10-autonoma/ y documentacion/. Ninguna evidencia publica contraseñas o JWT.

Escenario 1 Token válido

Inicio: 15/10/2026 18:35:53 -05
Fin: 15/10/2026 18:35:54 -05
Plataforma: Android · **HTTP recibido:** 200

Pasos exactos
Iniciar sesión como admin. Abrir Productos. Ejecutar GET productos con el mismo cliente autenticado.



Mensaje literal del campo message

La respuesta 200 es un DTO paginado y no incluye campo message.

La respuesta contiene los productos reales del catálogo y el estado paginado; el cuerpo completo está en bitacora.json. No se registra el token.

Qué vio el usuario
Productos: Inventario conectado

Conclusión
Una firma válida y un usuario activo permiten consultar el catálogo; la identidad y los permisos se comprueban en el backend.

Escenario 2 Token expirado

Inicio: 15/10/2026 18:36:02 -05
Fin: 15/10/2026 18:37:08 -05
Plataforma: Android · **HTTP recibido:** 401

Pasos exactos
Iniciar backend con TTL de un minuto. Hacer login nuevo. Abrir Productos y esperar 65 segundos reales. Ejecutar GET productos sin renovar el token.



Mensaje literal del campo message

El token ha expirado. Inicie sesión nuevamente


```
{
  "timestamp": "2026-10-15T18:37:06.661018700",
  "status": 401,
  "error": "Unauthorized",
  "message": "El token ha expirado. Inicie sesión nuevamente",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```


Qué vio el usuario
Tu sesión expiró. Inicia sesión nuevamente.

Conclusión
El vencimiento invalida una sesión sin intervención del usuario. La app detecta el 401, borra el token y vuelve al login.

Escenario 3 Token alterado

Inicio: 15/10/2026 18:37:14 -05
Fin: 15/10/2026 18:37:15 -05
Plataforma: Android · **HTTP recibido:** 401

Pasos exactos
Hacer login. Cambiar exactamente el primer carácter de la firma del JWT guardado. Vaciar la caché Bearer para leer el valor alterado. Ejecutar GET productos.



Mensaje literal del campo message

El token no es válido


```
{
  "timestamp": "2026-10-15T18:37:13.770809200",
  "status": 401,
  "error": "Unauthorized",
  "message": "El token no es válido",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```


Qué vio el usuario
Tu sesión expiró. Inicia sesión nuevamente.

Conclusión
Cambiar un carácter de la firma basta para invalidar el JWT. El servidor no confía en el contenido de un token alterado.

Escenario 4 Sin cabecera

Inicio: 15/10/2026 18:37:18 -05
Fin: 15/10/2026 18:37:19 -05
Plataforma: Android · **HTTP recibido:** 401

Pasos exactos
Hacer login y cerrar sesión. Lanzar GET productos con el mismo cliente Ktor, sin añadir Authorization.



Mensaje literal del campo message

Debe iniciar sesión para acceder a este recurso


```
{
  "timestamp": "2026-10-15T18:37:18.298944500",
  "status": 401,
  "error": "Unauthorized",
  "message": "Debe iniciar sesión para acceder a este recurso",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```


Qué vio el usuario
Formulario de login sin sesión

Conclusión
El logout elimina tanto el valor persistido como la caché del proveedor: la siguiente solicitud realmente llega anónima.

Escenario 5 Prefijo incorrecto

Inicio: 15/10/2026 18:37:24 -05
Fin: 15/10/2026 18:37:25 -05
Plataforma: Android · **HTTP recibido:** 401

Pasos exactos
Hacer login. Enviar Authorization con prefijo bearer en minúscula desde instrumentación. AuthCircuitBreaker impide que Ktor reemplace ese encabezado deliberado.



Mensaje literal del campo message

Debe iniciar sesión para acceder a este recurso


```
{
  "timestamp": "2026-10-15T18:37:24.350157800",
  "status": 401,
  "error": "Unauthorized",
  "message": "Debe iniciar sesión para acceder a este recurso",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```


Qué vio el usuario
Tu sesión expiró. Inicia sesión nuevamente.

Conclusión
El filtro del backend distingue el prefijo exacto Bearer. La variante deliberada en minúscula se interpreta como una petición anónima.

Escenario 6 Usuario deshabilitado

Inicio: 15/10/2026 18:37:30 -05
Fin: 15/10/2026 18:37:34 -05
Plataforma: Android · **HTTP recibido:** 401

Pasos exactos
Hacer login y mantener Productos abierto. En MySQL ejecutar UPDATE usuarios SET estado=b'0' WHERE username='admin'. Ejecutar GET productos y reactivar después con estado=b'1'.



Mensaje literal del campo message

El usuario está deshabilitado


```
{
  "timestamp": "2026-10-15T18:37:32.786743800",
  "status": 401,
  "error": "Unauthorized",
  "message": "El usuario está deshabilitado",
  "path": "/api/v1/productos",
  "validationErrors": null
}
```


Qué vio el usuario
Tu sesión expiró. Inicia sesión nuevamente.

Conclusión
El backend consulta el estado actual del usuario en cada petición. Deshabilitarlo revoca el acceso de un token todavía vigente.

PRODUCTO 2 / COMPROBACIÓN 1

Archivo del almacén cifrado

Se leyó el archivo real data/data/pe.edu.upeu.pharmamobil/shared_prefs/sesion_segura.xml desde el proceso de instrumentación y se exportó mediante ADB. El ensayo comprueba que el JWT leído con AlmacenSeguro no aparece en el XML en claro.



Figura 7. Vista del XML real exportado del emulador. La clave de sesión y su valor están cifrados. Los keysets de AndroidX están plegados; esta vista no se presenta como una captura de Device Explorer.

Resultado verificado: token_legible=false. Se usa EncryptedSharedPreferences con MasterKey AES256_GCM, cifrado de nombres AES256_SIV y valores AES256_GCM. El acceso descifrado solo se realiza mediante el almacén de la app.

Reproducción en Android Studio: Device Explorer > data/data/pe.edu.upeu.pharmamobil/shared_prefs/sesion_segura.xml. Los originales antes y después del logout se incluyen como XML para inspección independiente.

PRODUCTO 2 / COMPROBACIÓN 2

Registro de Authorization saneado

Se capturó adb logcat del emulador y se conservaron únicamente líneas Ktor. Authorization aparece como ***; se oculta todo el valor, incluido el prefijo, en lugar de exponer el JWT. Esta redacción satisface el propósito de Bearer *** sin conservar ninguna credencial.

Registro real de Ktor

Logcat del emulador · Primeras solicitudes de los ensayos · Authorization saneada

```
10-15 23:35:44.848 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/auth/login
10-15 23:35:45.465 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:35:47.126 I/System.out( 5527): Ktor: REQUEST: http://10.0.2.2:8080/api/v1/auth/me
10-15 23:35:47.126 I/System.out( 5527): -> Authorization: ***
10-15 23:35:47.721 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:35:52.074 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/productos?pagina=0&tamanio=20&ordenarPor=nombre&direccion=asc
10-15 23:35:52.074 I/System.out( 5527): -> Authorization: ***
10-15 23:35:53.141 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:35:53.769 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/productos
10-15 23:35:53.770 I/System.out( 5527): -> Authorization: ***
10-15 23:35:54.299 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:35:56.910 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/auth/login
10-15 23:35:57.486 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:35:57.793 I/System.out( 5527): Ktor: REQUEST: http://10.0.2.2:8080/api/v1/auth/me
10-15 23:35:57.793 I/System.out( 5527): -> Authorization: ***
10-15 23:35:58.470 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:36:00.942 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/productos?pagina=0&tamanio=20&ordenarPor=nombre&direccion=asc
10-15 23:36:00.943 I/System.out( 5527): -> Authorization: ***
10-15 23:36:01.574 I/System.out( 5527): Ktor: RESPONSE: 200
10-15 23:37:07.028 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/productos
10-15 23:37:07.028 I/System.out( 5527): -> Authorization: ***
10-15 23:37:07.561 I/System.out( 5527): Ktor: RESPONSE: 401
10-15 23:37:09.396 I/System.out( 5527): Ktor: REQUEST:
http://10.0.2.2:8080/api/v1/auth/login
10-15 23:37:09.939 I/System.out( 5527): Ktor: RESPONSE: 200
```

Vista del archivo exportado mediante adb logcat. No se registra el cuerpo del login ni el JWT.

Figura 8. Visor del registro real. Logging usa HEADERS únicamente en depuración y NONE en release. No se guardan cuerpos de login ni respuestas con JWT. El TXT íntegro saneado está en evidencias/sesion10-autonoma/ktor-saneado.txt.

PRODUCTO 2 / COMPROBACIÓN 3

Sesión persistente tras cerrar el proceso

Después de un login válido el ejecutor realizó am force-stop pe.edu.upeu.pharmamobil, abrió MainActivity y comprobó el token persistido en una nueva instrumentación. /auth/me reconstruyó la sesión sin introducir credenciales.

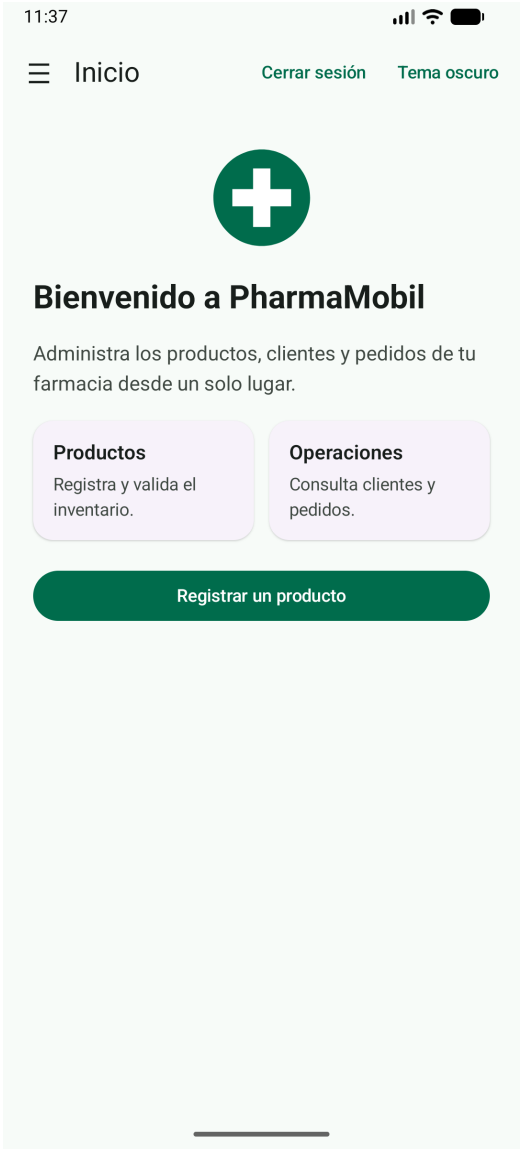


Figura 9. Sesión antes de detener por completo el proceso.

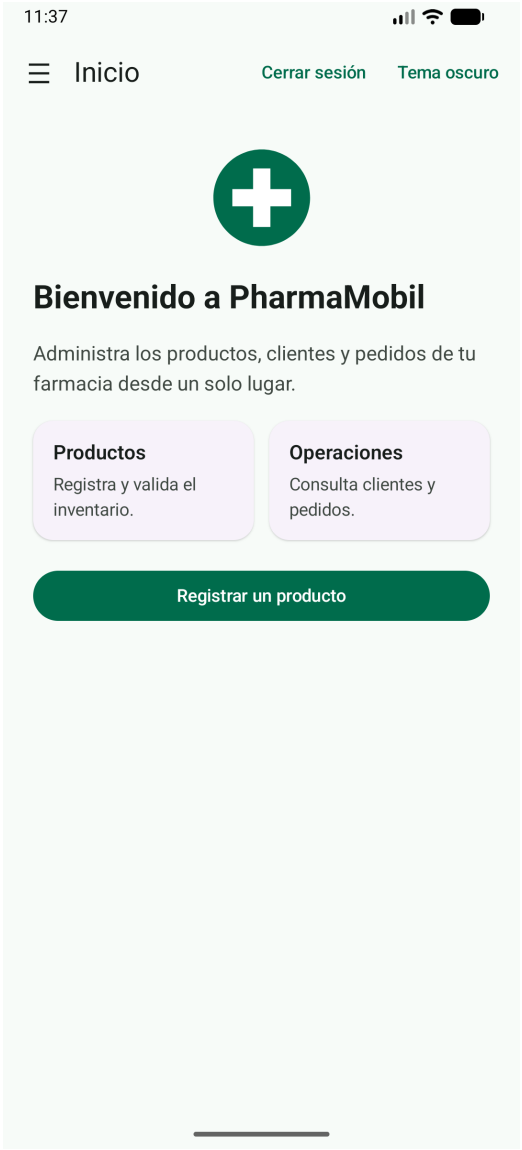


Figura 10. Sesión restaurada después de force-stop y reapertura.

Conclusión: el JWT cifrado sobrevive a la muerte del proceso. La prueba no se limita a cambiar de pantalla ni a conservar una variable en memoria. El servidor sigue validando firma, expiración y usuario al restaurar.

PRODUCTO 3 / CUATRO EFECTOS

Cierre de sesión completo

Orden	Verificación real	Resultado
1	AlmacenSeguro.leerToken() es null. El XML ya no contiene la entrada cifrada de sesión.	Aprobado
2	GET productos válido antes del logout; GET posterior con el mismo cliente devuelve 401 anónimo.	Aprobado
3	SesionViewModel reinicia el estado; no quedan identidad ni datos de la sesión en el login.	Aprobado
4	Pulsar Atrás y reabrir no muestra Inventario conectado. Sigue el formulario de login.	Aprobado



Figura 11. Login tras el cierre.



Figura 12. Atrás y reapertura sin sesión.

Respuesta posterior al cierre

HTTP 401 · Debe iniciar sesión para acceder a este recurso

La lectura del almacén después del cierre se conserva en almacen-despues-logout.xml. Solo permanecen los keysets internos; no equivalen a un JWT activo. La caché Bearer se vacía explícitamente en AuthRepositorioRest.cerrarSesion().

PRODUCTO 4 / TRES USUARIOS

Matriz HTTP y disponibilidad de interfaz

Operación	admin	vendedor	almacen
Listar productos	200 / Sí	200 / Sí	200 / Sí
Registrar producto	201 / Sí	403 / No	201 / Sí
Listar clientes	200 / Sí	200 / Sí	403 / No
Registrar venta	201 / Pedido demo	201 / Pedido demo	403 / No
Ver reportes	200 / No hay pantalla	403 / No hay pantalla	403 / No hay pantalla
Consultar /auth/me	200 / Automática	200 / Automática	200 / Automática

Cada celda registra HTTP / interfaz. Los códigos proceden de la API real y la disponibilidad del menú se comprobó en Android. La ausencia de una acción permitida no es un 403 ofrecido por error.

Alcance de cada acción

Productos está integrado con REST. Clientes tiene pantalla demostrativa visible para ADMIN y VENDEDOR. Registrar pedido también es una demostración local, no un POST de venta; el registro de venta real de esta matriz se ejecutó directamente contra la API. Reportes no tiene pantalla y /auth/me es automático al restaurar.

Hallazgo y evaluación

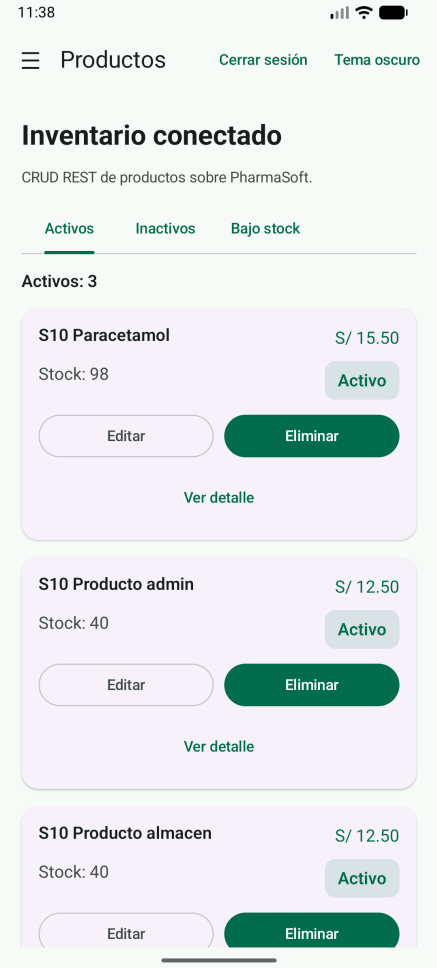
No se ofrecieron acciones de escritura de catálogo a VENDEDOR ni Clientes/Pedidos a ALMACENERO. El proyecto no presenta el menú como prueba de que todos esos módulos consumen REST. Se conserva esa distinción para no atribuir funcionalidades no implementadas.

Fuente: matriz-http.json (18 operaciones) e interfaz-roles.json (observación de tres usuarios). Sin token el catálogo devuelve 401.

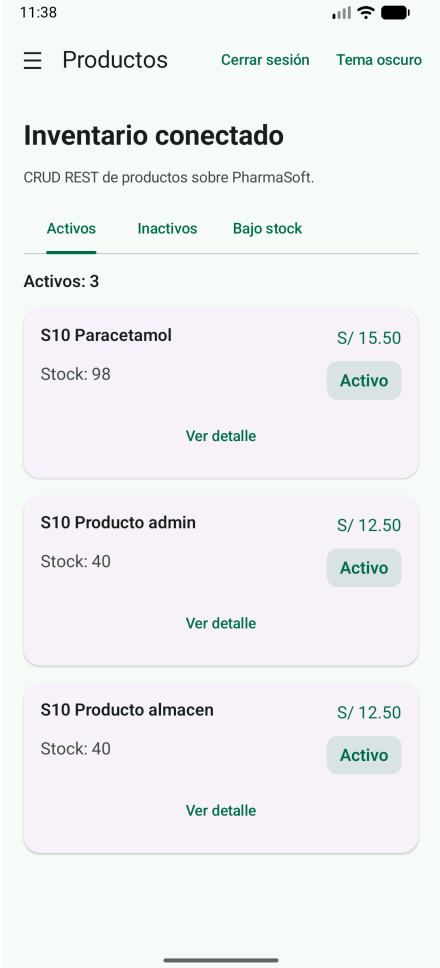
PRODUCTO 4 / INTERFAZ REAL

Capturas de permisos por rol

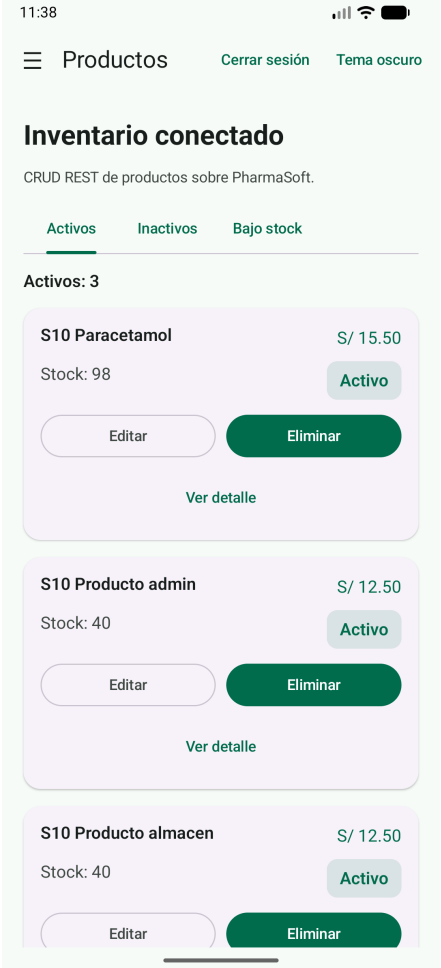
Las capturas corresponden a la misma app y al backend MySQL de la actividad. ADMIN y ALMACENERO ven edición y eliminación; VENDEDOR dispone de consulta.



ADMIN



VENDEDOR



ALMACEN

Comprobaciones de menú

ADMIN y VENDEDOR tienen Clientes y Pedidos. ALMACENERO no los tiene. Las capturas inicio-usuario.png y menu-usuario.png se entregan junto a las de Productos para verificar esa observación.

La acción deliberada de un escenario se inyecta desde instrumentación y no añade botones de prueba a la aplicación de producción.

ACTIVIDAD AUTÓNOMA N.º 10

Análisis y commits del desarrollo

Hallazgos

1. Ktor reemplaza normalmente Authorization mediante su proveedor Bearer. El ensayo de prefijo incorrecto necesita AuthCircuitBreaker para preservar la cabecera deliberada.
2. Las excepciones 401 protegidas limpian el almacén y la caché y notifican a la UI. Se detectaron expiración y deshabilitación reales, sin dejar una sesión que aparentara estar activa.
3. Los keysets de AndroidX permanecen tras el logout; comprobar archivo vacío sería incorrecto. Se verifica la desaparición de la entrada de sesión y leerToken()==null.
4. El runner drena la salida de instrumentación en un hilo para no bloquearse si una aserción genera una traza extensa.

Commit	Fecha y hora	Cambio
0494dfc	2026-10-15 18:43	test(jwt): cubrir seis escenarios de token y mensajes del filtro
eb75421	2026-10-15 18:43	feat(jwt): configurar expiracion MySQL por entorno con valor seguro de 60 minutos
275d5c7	2026-10-15 18:43	test(android): ejecutar bitacora real cifrado persistencia logout y permisos
7e2a66b	2026-10-15 18:43	docs(autonoma): documentar reproduccion y capturar archivos reales del dispositivo

Los commits registran el momento real del trabajo. No se retrocedieron fechas para aparentar un desarrollo durante otra sesión. La rama se integra mediante un merge revisable en GitHub.

Código y evidencias de la rama

Historial completo de commits

ACTIVIDAD AUTÓNOMA N.º 10

Reproducción y lista de cotejo

El procedimiento detallado está en docs/sesion10-actividad-autonoma.md. Antes de ejecutar: iniciar MySQL y el emulador, cargar las claves locales y establecer MYSQL_BIN. El script de pruebas no publica secretos.

```
java -jar target/PharmaBackend-0.0.1-SNAPSHOT.jar `
  --spring.profiles.active=mysql --app.jwt.expiracion-minutos=1
# Esperar el arranque, desde la raíz del proyecto:
python ci/ejecutar_autonoma_s10.py
# Al terminar: reiniciar el backend con expiración 60.
```

Criterio de la guía	Estado
PDF con nombre solicitado, portada, sesión, fecha y enlace	Sí
Seis escenarios con captura, HTTP y mensaje literal	Sí; 200 no contiene campo message
Expiración detectada y regreso al login	Sí, espera real de 65 segundos
Archivo de almacén no legible y log saneado	Sí, XML/ADB y Logcat reales
Cuatro efectos del logout, incluido el cliente HTTP	Sí
Matriz con tres usuarios y conducta de interfaz	Sí, con alcance demo/REST explícito
Expiración restaurada y admin reactivado	Sí, 3600 segundos y estado 1
Commits accesibles en la rama de entrega	Sí

Postman

Se entrega documentacion/S10_Autonomia_Postman.json para importar. La actividad no exige esa herramienta; las evidencias HTTP de este informe provienen de Android/Ktor. No se presentan vistas de archivos como si fueran Postman o Device Explorer.

Referencias y procedencia

Guía docente: Actividad Autónoma N.º 10, Validación de expiración, almacenamiento y cierre de sesión, 7 páginas, entrega 19/10/2026. Código del backend basado en dreyna/pharmaSoft, fff44f9. Fuentes de ejecución: bitacora.json, logout.json, interfaz-roles.json, matriz-http.json y restauracion-final.json.